

NORTHSTAR FINANCIAL GROUP

BC/DR Tabletop Exercise

After-Action Report & Improvement Plan

PORTFOLIO SIMULATION - NO REAL CLIENT DATA

Northstar Financial Group is a fictional organization used to demonstrate business continuity, disaster recovery, risk analysis, and executive communication skills.

Prepared by Ryan Bryant | Cybersecurity Analyst Candidate

Version 1.0 | September 2026

Document Control

Control	Value
Document owner	Northstar BC/DR Program - simulated
Prepared by	Ryan Bryant
Version	1.0
Date	September 2026
Purpose	Record the decisions, strengths, gaps, and corrective actions identified during a simulated headquarters-loss BC/DR tabletop exercise.
Intended audience	Executive leadership, IT, Security, Finance, HR, Legal/Compliance, and continuity stakeholders
Classification	Portfolio Simulation / No Real Client Data
Review cycle	At least annually and after material technology, vendor, facility, or business-process changes

1. Exercise Overview

Exercise scenario: an electrical fire makes Northstar headquarters inaccessible for at least three weeks. Cloud-hosted Microsoft 365, CRM, Payroll, and HRIS remain available. The exercise tests personnel safety, plan activation, alternate operations, recovery sequencing, RTO/RPO decision-making, security monitoring during recovery, and third-party resilience.

Exercise Objectives

- Validate the first actions taken after loss of the headquarters facility.
- Validate recovery priority and dependency decisions.
- Test whether available recovery data meets approved RPOs.
- Test security investigation and privileged-access monitoring during recovery.
- Test whether third-party/cloud recovery services create new single points of failure.

OVERALL ASSESSMENT

Capable with material gaps. Decision-making was strong, but the exercise exposed technical and governance weaknesses that could prevent Northstar from meeting approved recovery objectives.

2. Scenario Timeline and Inject Decisions

Inject	Condition	Decision
Inject 1 - 6:40-7:05 AM	Electrical fire damages headquarters; building inaccessible; AD, Finance repository, local NAS, and HQ VPN unavailable.	Prioritize personnel safety and accountability; activate BC/DR; establish alternate operations; begin Tier 0 recovery; restore security visibility; communicate verified impacts.
Inject 2 - 8:20 AM	Off-site Finance backup is available but six hours stale against a 1-hour RPO.	Restore best available copy but do not declare RPO met. Reconstruct missing records from approved secondary evidence and require secondary Finance validation before declaring recovery complete.
Inject 3 - 10:15 AM	Fourteen failed sign-ins target an administrator account from an unfamiliar external IP. No successful authentication confirmed.	Continue disaster recovery while opening a parallel security investigation. Preserve logs, prioritize privileged identities, validate sessions/MFA/role changes, and pause only a specific recovery activity if evidence shows compromise.
Inject 4 - 1:30 PM	Cloud backup provider management portal is unavailable for 8-12 hours while headquarters remains inaccessible.	Continue operations but establish an independent secondary recovery copy immediately, beginning with Tier 0/Tier 1 data. Do not rely on one cloud provider as the sole off-site recovery path.

3. Strengths Demonstrated

- Human safety and accountability were treated as the first priority before technology recovery.
- Recovery priorities reflected dependencies rather than simply ranking systems by business importance.
- The exercise distinguished technical restoration from successful recovery against an approved RPO.
- Finance reconciliation used controlled reconstruction and secondary validation rather than allowing a single employee to amend all recovered records.
- Disaster recovery continued while Security investigated suspicious activity, avoiding both threat neglect and unnecessary recovery shutdown.
- The team recognized that moving backups to the cloud can transfer rather than eliminate concentration risk.
- External communications were tied to confirmed impact rather than speculation.

4. Gaps Identified

ID	Gap	Priority
AAR-01	1-hour RPOs are not demonstrated by nightly backup capability	Critical
AAR-02	Production and primary backup share the same headquarters failure domain	Critical

ID	Gap	Priority
AAR-03	No fully tested restoration capability	Critical
AAR-04	Headquarters loss can remove remote-access infrastructure	High
AAR-05	Identity/DNS recovery can depend on headquarters infrastructure	Critical
AAR-06	Security-during-recovery procedures are not formally defined	High
AAR-07	Cloud backup provider can become a new recovery bottleneck	High
AAR-08	Manual continuity and reconciliation procedures require formal templates and ownership	High

5. Improvement Plan

Action	Corrective action	Owner	Target	Validation
IP-01	Implement hourly-capable recovery points for 1-hour RPO workloads	IT / Business Owners	30-60 days	Test restore timestamp and data integrity.
IP-02	Create encrypted off-site and immutable/offline recovery copies	IT	0-30 days	Verify no shared credential or platform can delete all copies.
IP-03	Perform Tier 0/Tier 1 full restore tests	IT / BC-DR Coordinator	0-60 days	Measure achieved RTO/RPO; document defects.
IP-04	Implement geographically independent alternate remote access	IT	31-60 days	Test with headquarters network disabled.
IP-05	Establish separated identity/DNS recovery and break-glass access	IT / IAM	31-60 days	Test admin authentication without headquarters.
IP-06	Add security workstream and pause criteria to BC/DR SOP	Security / IT	0-30 days	Exercise privileged-account validation during next tabletop.
IP-07	Establish independent secondary recovery copy/provider path	IT / Vendor Management	31-90 days	Exercise provider outage scenario.

Action	Corrective action	Owner	Target	Validation
IP-08	Create controlled manual continuity and reconciliation forms	Finance / HR / BC-DR Coordinator	0-30 days	Test duplicate prevention, approvals, and secure storage.

6. Key Lessons Learned

- A recovery service should not share the same failure domain as the system it is intended to recover.
- RTO/RPO objectives are business requirements; recovery technology must be proven against them through testing.
- Restoring a system does not mean the organization met its recovery objective if the available data is too old.
- Recovery and security investigation can operate in parallel, with targeted pause criteria based on evidence.
- Manual continuity procedures must include secure recordkeeping, reconciliation, and secondary validation.
- Cloud services require resilience planning, administrative oversight, contractual review, and alternate recovery paths.
- Business criticality changes with time and scenario - especially Payroll, VPN, and Security/Logging.

7. Recommended Next Exercise

Within 90 days, run a follow-up exercise after corrective actions are implemented. The next scenario should disable headquarters connectivity and the primary cloud backup provider simultaneously, require restoration of one Tier 1 workload from the independent recovery copy, and validate the actual elapsed RTO/RPO against the approved BIA.

CLOSURE CRITERIA

The exercise improvement plan should remain open until each corrective action has an owner, due date, validation method, and documented evidence of completion.

Appendix. Reference Frameworks

NIST SP 800-34 Rev. 1: <https://doi.org/10.6028/NIST.SP.800-34r1>

Ready.gov Business Continuity Plan: <https://www.ready.gov/sites/default/files/2020-03/business-continuity-plan.pdf>

CISA #StopRansomware Guide: <https://www.cisa.gov/stopransomware/ransomware-guide>